

IT-Sicherheit - SNORT

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Einführung

- IDS – Intrusion Detection System
- IPS – Intrusion Prevention System
IDS & aktiver Schutz vor aktuellen Angriffen
- Kategorien
 - NIDS Network IDS
Analysiert Datenverkehr im Netzwerk
Abgleich mit Signaturen aus Datenbank
 - HIDS Host IDS
Analysiert aktuelles System
Untersucht System Log Meldungen
 - Hybrides IDS – Kombination.

Strategien zur Erkennung

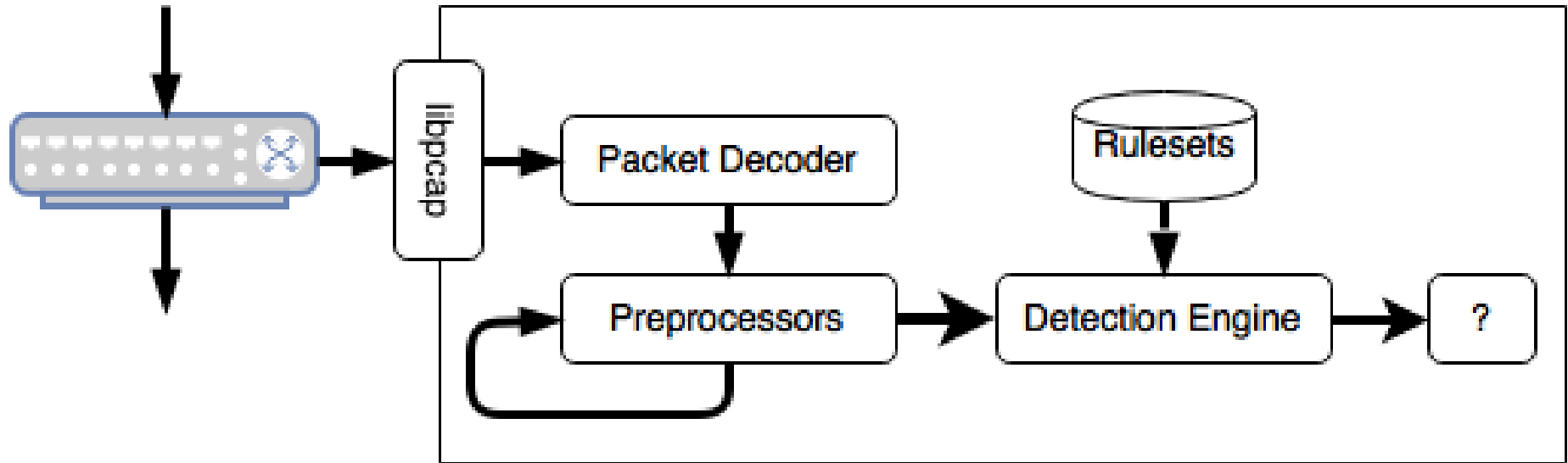
- Pattern
 - Signaturen bekannter Angriffe
- Anomalie
 - Nicht normales Verhalten
 - Lernphase
- Vorteile/Nachteile

Werkzeuge SNORT

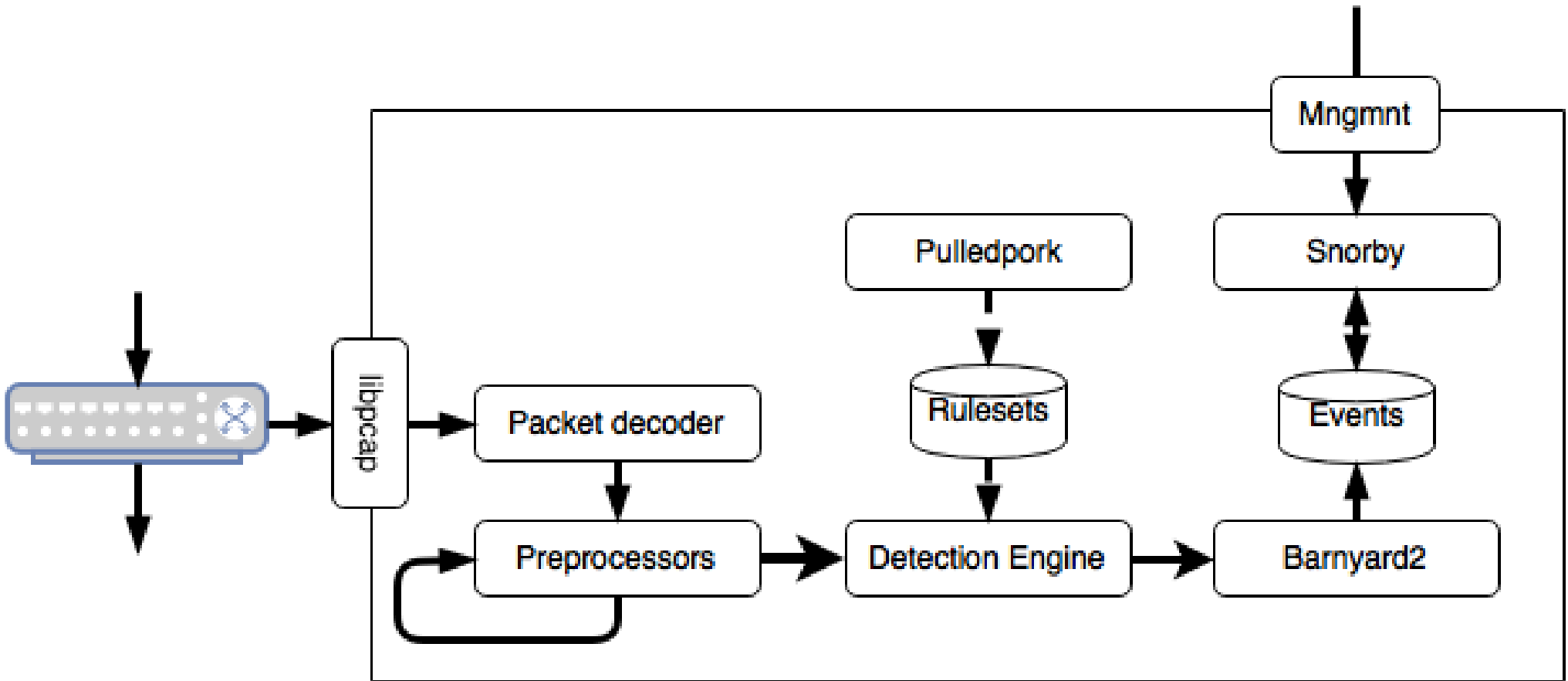


- NIDS & NIPS
 - Schwerpunkt Pattern, aber auch Anomalie
 - Dynamische Regeln
 - Erfahrung notwendig für die Nutzung
-
- 1998 Entwickler Martin Rösch, 1999
 - Ab 2001 Unterstützung Chris Green
 - 2003-2013 Sourcefire Inc
 - 2009 – eine der besten Open Source SW aller Zeiten
 - Seit Ende 2013 weiterentwickelt von Cisco.
 - Seit 2021 Snort 3 – neu implementiert in C++

SNORT Basissystem



SNORT mit Ergänzungen





IT-Sicherheit / Prof. Dr. Freudenmann

Start SNORT

```
root@snort29:~# snort -v
Running in packet dump mode

--== Initializing Snort ==--
Initializing Output Plugins!
pcap DAQ configured to passive.
Acquiring network traffic from "eth0".
Decoding Ethernet

--== Initialization Complete ==--

-*> Snort! <*-
o''')~ Version 2.9.8.0 GRE (Build 229)
  ''') By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014-2015 Cisco and/or its affiliates. All rights reserved.

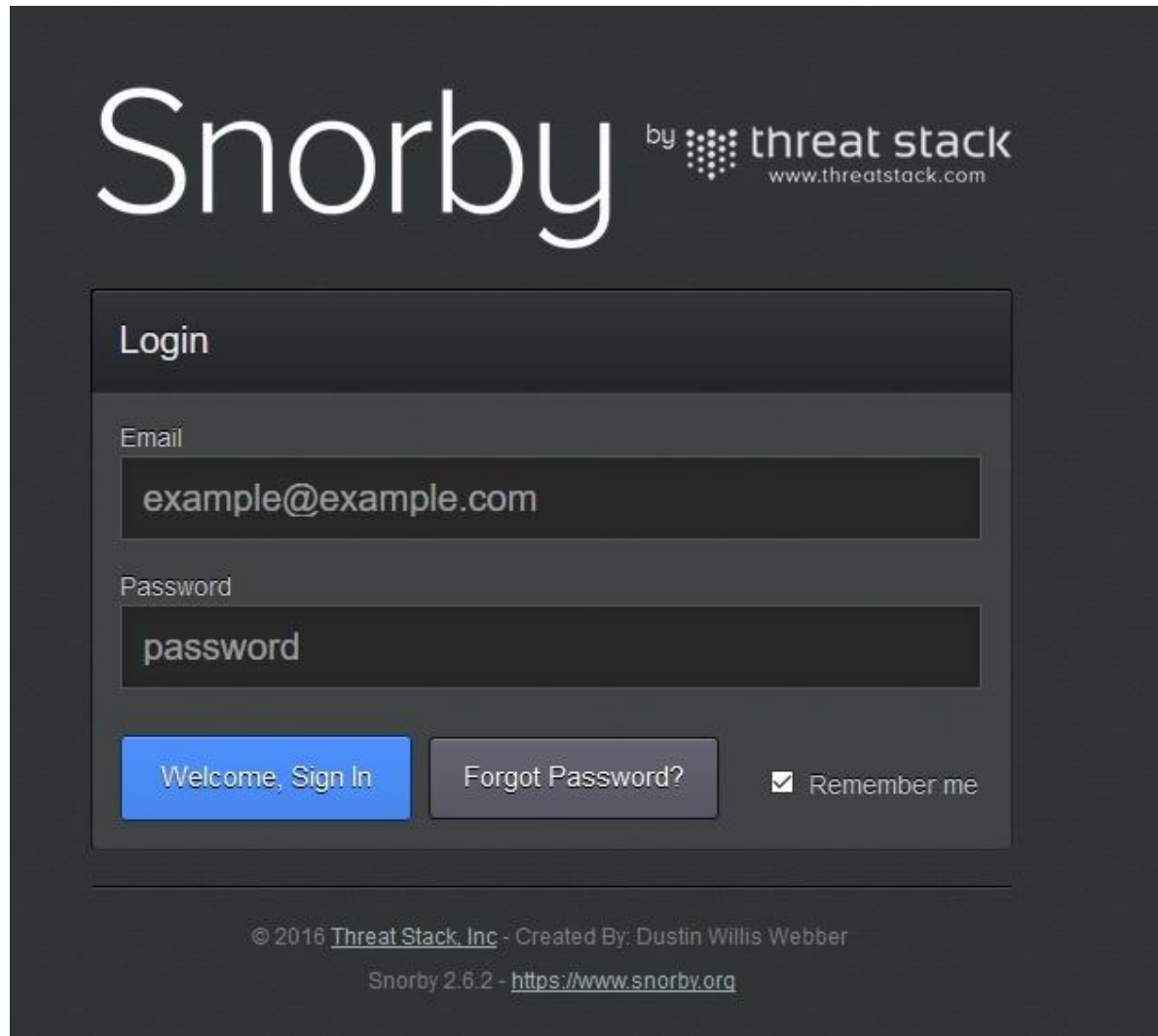
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.6.2
Using PCRE version: 8.35 2014-04-04
Using ZLIB version: 1.2.8

Commencing packet processing (pid=6309)
```


SNORT Start

- Command Line Tool
 - Viele Konfigurationsmöglichkeiten
 - Sniffer Mode
 - Packet Logger Mode
 - NIDS Mode
 - Aktiv und Passiv einsetzbar
Snort-Mode „Inline“ oder „Passive“

Snorby - GUI

The image shows the Snorby login interface. At the top, the word "Snorby" is displayed in a large, white, sans-serif font. To its right, the text "by threat stack" is shown in a smaller font, with a logo consisting of a grid of dots. Below the main title, the word "Login" is centered in a white font. The login form consists of two input fields: "Email" and "Password". The "Email" field contains the text "example@example.com" and the "Password" field contains the text "password". Below the input fields, there are three buttons: "Welcome, Sign In" (highlighted in blue), "Forgot Password?" (in a grey box), and a checkbox labeled "Remember me" which is checked. At the bottom of the form, there is a copyright notice: "© 2016 Threat Stack, Inc - Created By: Dustin Willis Webber" and the version information: "Snorby 2.6.2 - https://www.snorby.org".

Snorby by threat stack
www.threatstack.com

Login

Email
example@example.com

Password
password

Welcome, Sign In Forgot Password? ☒ Remember me

© 2016 Threat Stack, Inc - Created By: Dustin Willis Webber
Snorby 2.6.2 - <https://www.snorby.org>

Dashboard

My Queue (0)

Events

Sensors

Search

Administration

Dashboard

 More Options

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 10:07 AM UTC

0

HIGH SEVERITY

0 / 0

0

MEDIUM SEVERITY

0 / 0

0

LOW SEVERITY

0 / 0

Sensors

Severities

Protocols

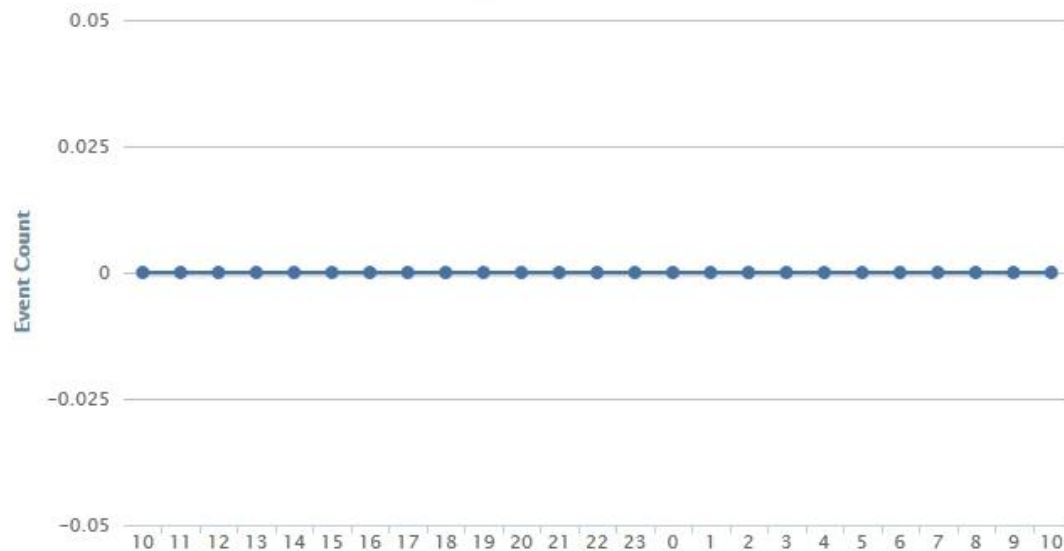
Signatures

Sources

Destinations

Event Count vs Time By Sensor

 snort29



Last 24 Hours

TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

Severities

Protocols

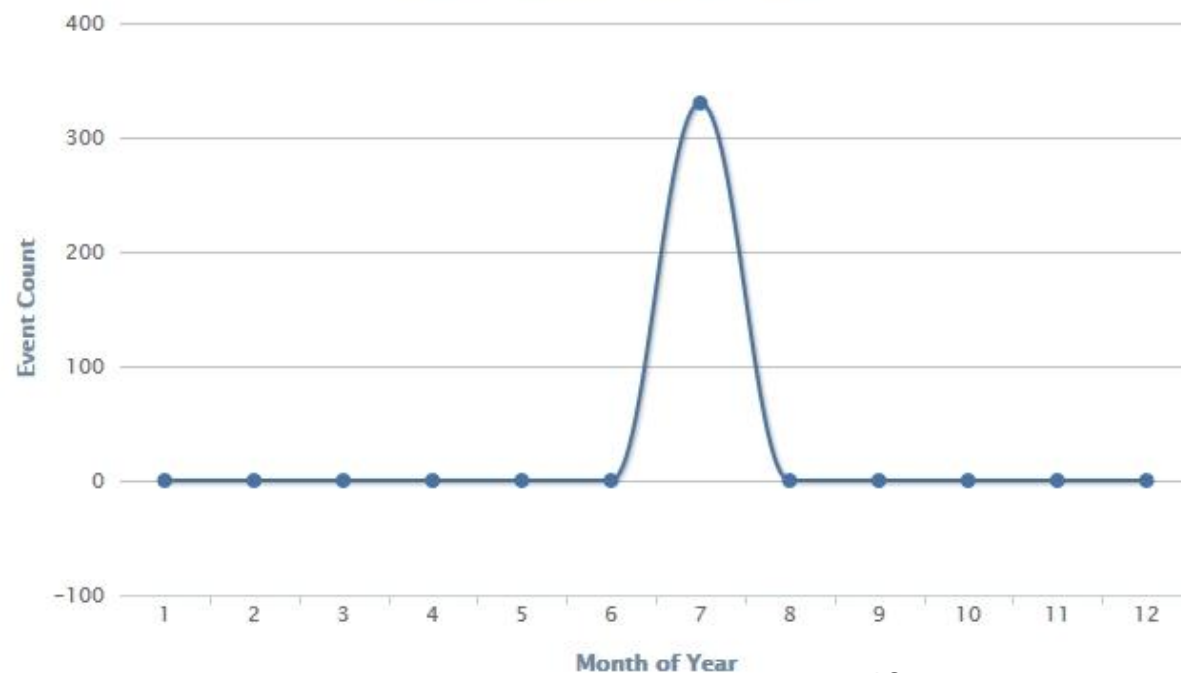
Signatures

Sources

Destinations

Event Count vs Time By Sensor

snort29



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

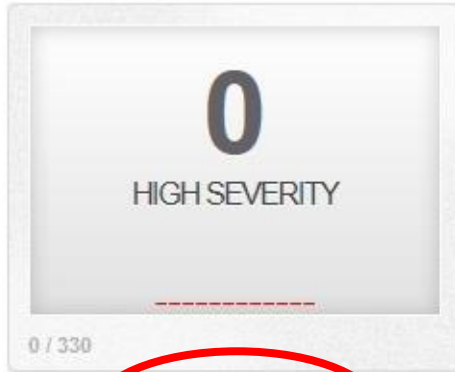
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

Severities

Protocols

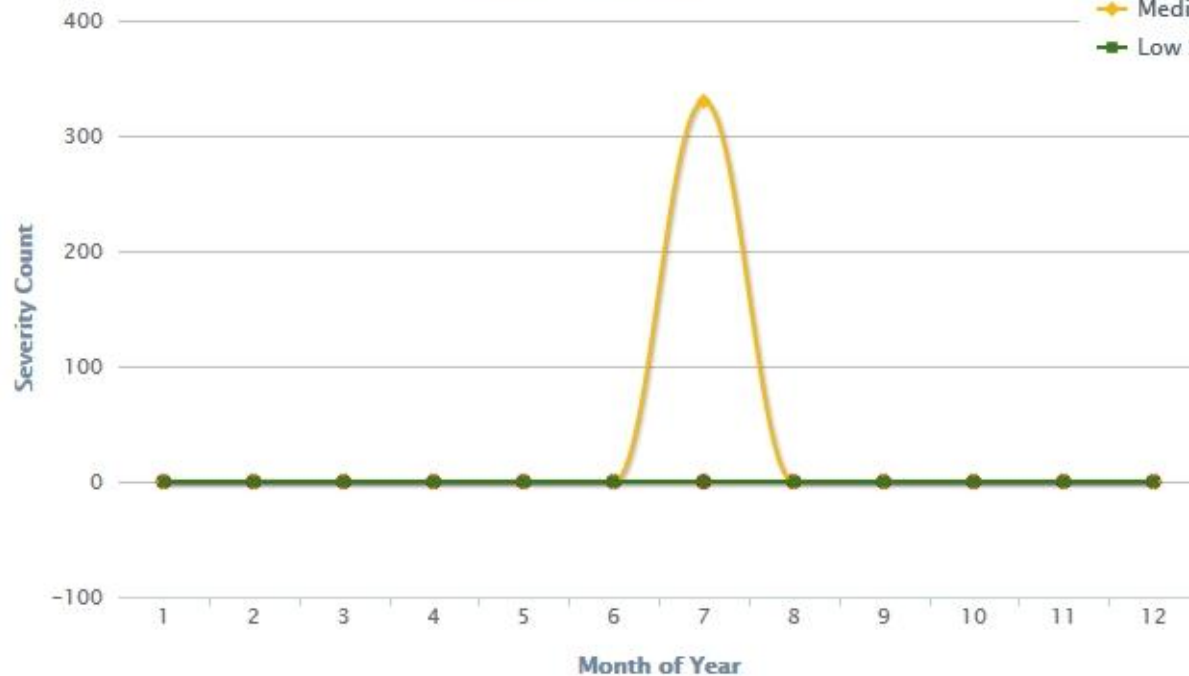
Signatures

Sources

Destinations

Severity Count vs Time

High Severity
Medium Severity
Low Severity



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

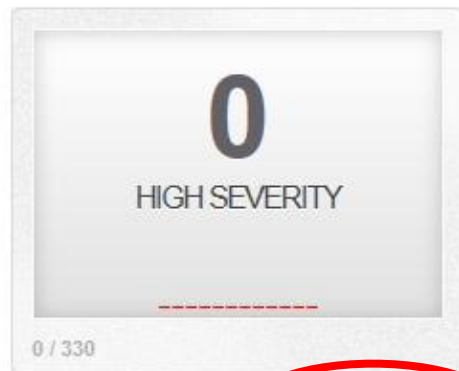
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 11:00 AM UTC



Sensors

Severities

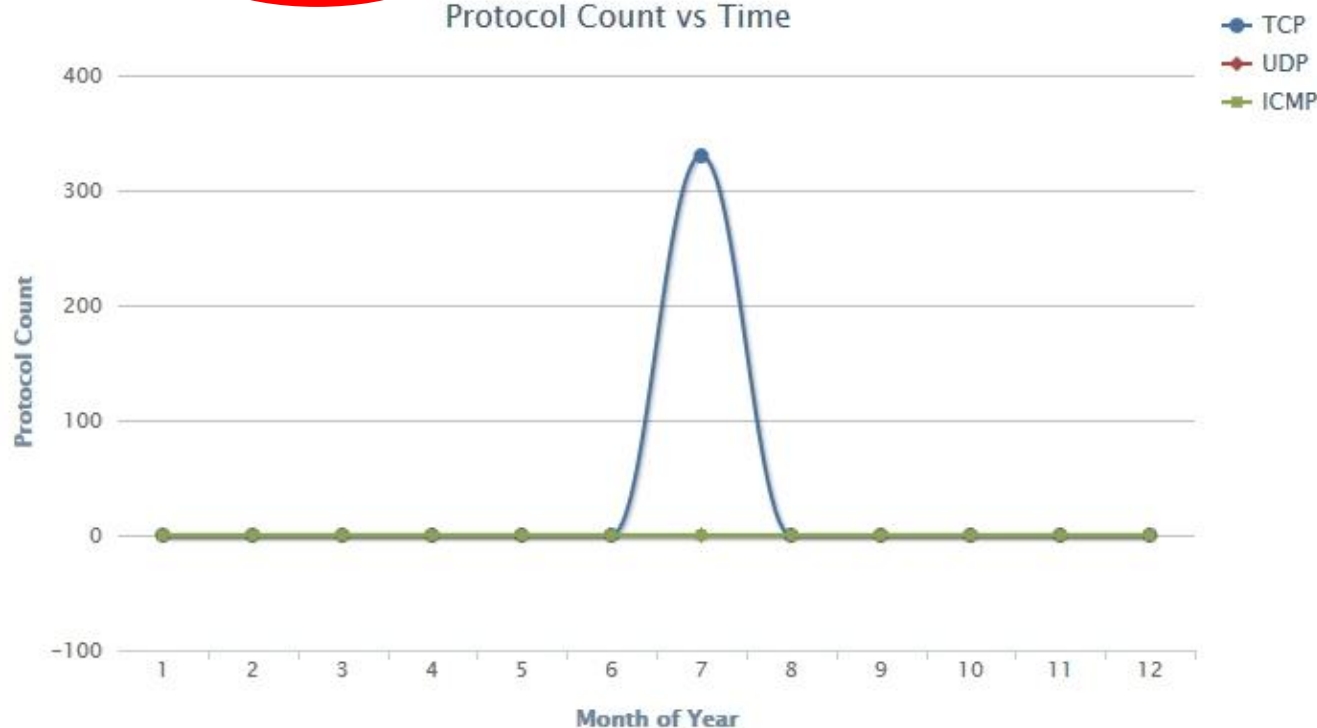
Protocols

Signatures

Sources

Destinations

Protocol Count vs Time



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

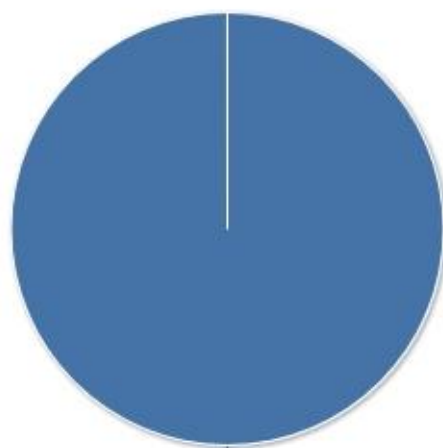
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC

Sensors Severities **Protocols** Signatures Sources Destinations

http_inspect: LONG HEADER... (100%)

TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

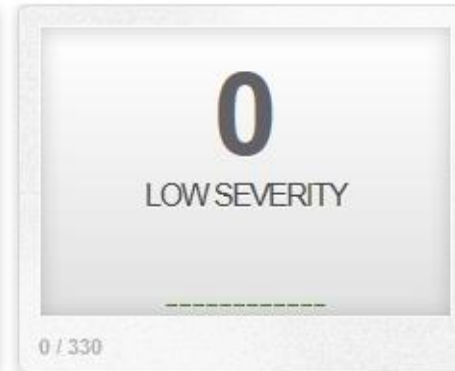
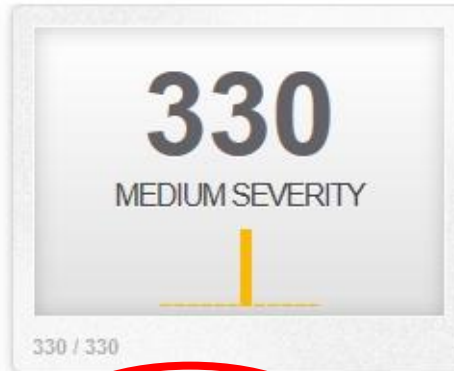
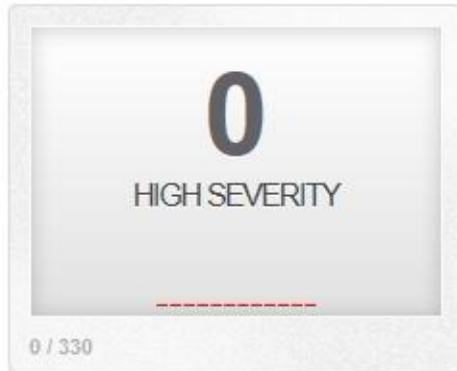
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

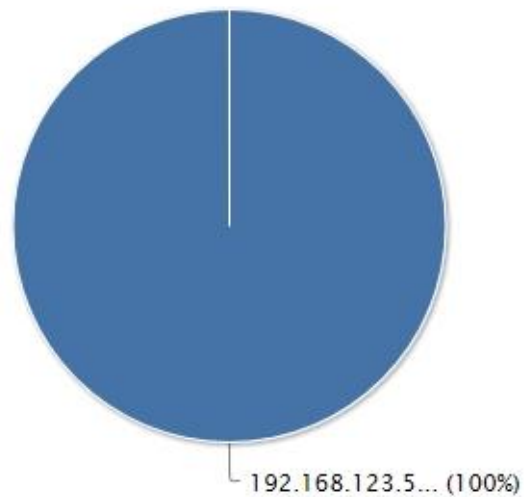
Severities

Protocols

Signatures

Sources

Destinations



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

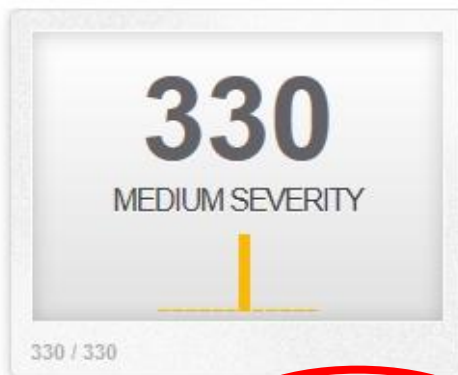
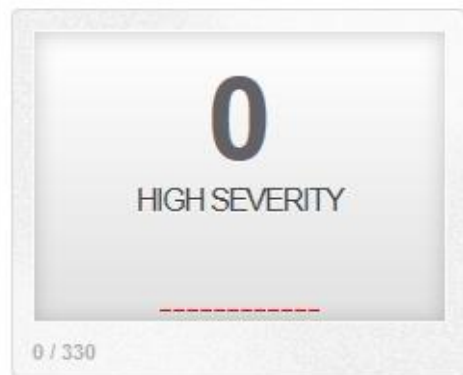
Reconnaissance 0

Virus Infection 0

False Positive 0

LAST 24 TODAY YESTERDAY LAST WEEK THIS MONTH THIS QUARTER THIS YEAR

Updated: 09/05/16 06:00 AM UTC



Sensors

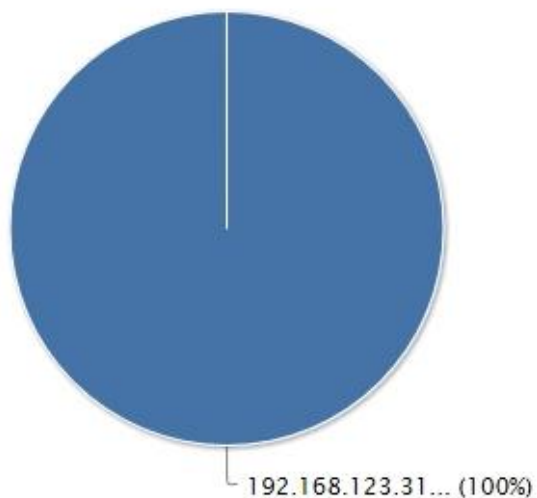
Severities

Protocols

Signatures

Sources

Destinations



TOP 5 SENSOR

snort29 330

TOP 5 ACTIVE USERS

 Administrator 0

LAST 5 UNIQUE EVENTS

http_inspect: LONG HEADER 330

ANALYST CLASSIFIED EVENTS

Unauthorized Root Access 0

Unauthorized User Access 0

Attempted Unauthorized... 0

Denial of Service Attack 0

Policy Violation 0

Reconnaissance 0

Virus Infection 0

False Positive 0

Snorby Event View Classify

The screenshot shows the Snorby web interface. At the top, the Snorby logo is on the left, and 'SPONSORED BY threat stack' is in the center. On the right, it says 'Welcome Administrator' with links for 'Settings' and 'Log out'. Below this is a navigation bar with tabs: 'Dashboard', 'My Queue (1)', 'Events', 'Sensors', 'Search', and 'Administration'. The 'Events' tab is selected and circled in red. Below the navigation bar, the 'Listing Sessions' section shows '(1 unique unclassified sessions)'. A table lists sessions with columns: 'Sev.', 'Sensor', 'Source IP', 'Destination IP', and 'Event Signature'. One session is listed with severity '2' (yellow square), sensor 'snort29', source IP '192.168.123.5', destination IP '192.168.123.31', and event signature 'http_inspect: LONG HEADER'. To the right of the table, there are buttons for 'Hotkeys', 'Classify Event(s)' (circled in red), and 'Filter Options'. A dropdown menu is open from the 'Classify Event(s)' button, showing a list of classification options: 'Unauthorized Root Access' (f1), 'Unauthorized User Access' (f2), 'Attempted Unauthorized Access' (f3), 'Denial of Service Attack' (f4), 'Policy Violation' (f5), 'Reconnaissance' (f6), 'Virus Infection' (f7), 'False Positive' (f8), and 'Unclassified' (ctrl+shift+u). On the far right, a 'Sessions' summary box shows '2016' and '330' sessions.

Snorby 2.6.2 - <https://www.snorby.org/>

By: Dustin Willis Webber

Listing Sessions (1 unique undclassified sessions)

Hotkeys

Classify Event(s)

Filter Options

☐	Sev.	Sensor	Source IP	Destination IP	Event Signature	Timestamp	Sessions
☐	★	2	snort29	192.168.123.5	192.168.123.31	http_inspect: LONG HEADER	07/06/2016 330

IP Header Information

View All Sessions

Perform Mass Classification

Event Export Options

Permalink

Source	Destination	Ver	Hlen	Tos	Len	ID	Flags	Off	TTL	Proto	Csum
192.168.123.5	192.168.123.31	4	5	0	905	26860	0	0	128	6	5901

Signature Information

Generator ID	Sig. ID	Sig. Revision	Activity (330/330)	Category	Sig Info
119	19	1	100.00%	bad-unknown	Query Signature Database View Rule

TCP Header Information

Src Port	Dst Port	Seq	Ack	Off	Res	Flags	Win	Csum	URP
4440	80	2530059464	2979320266	5	0	24	260	14017	0

References

Type	Value
cve	2009-4873

Payload

Hex

Ascii

```
00000000: 47 45 54 20 2f 69 6d 61 67 65 73 2f 6d 65 6e 75 2d 61 72 72 6f 77 2e 70 6e 67 GET./images/menu-arrow.png
000001A: 3f 31 33 32 38 34 35 37 33 34 39 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 74 ?1328457349.HTTP/1.1..Host
0000034: 3a 20 31 39 32 2e 31 36 38 2e 31 32 33 2e 33 31 0d 0a 55 73 65 72 2d 41 67 65 :.192.168.123.31..User-Age
000004E: 6e 74 3a 20 4d 6f 7a 69 6c 6c 61 2f 35 2e 30 20 28 57 69 6e 64 6f 77 73 20 4e nt:.Mozilla/5.0.(Windows.N
0000068: 54 20 31 30 2e 30 3b 20 57 4f 57 36 34 3b 20 72 76 3a 34 38 2e 30 29 20 47 65 T.10.0;.WOW64;.rv:48.0).Ge
0000082: 63 6b 6f 2f 32 30 31 30 30 31 30 31 20 46 69 72 65 66 6f 78 2f 34 38 2e 30 0d cko/20100101.Firefox/48.0.
000009C: 0a 41 63 63 65 70 74 3a 20 2a 2f 2a 0d 0a 41 63 63 65 70 74 2d 4c 61 6e 67 75 .Accept:/*/*..Accept-Langu
```



Snort

Home

Snort Signature Information

Rule

--

Sid

119-19

--

Summary:

This event is generated when the http_inspect preprocessor detects anomalous network traffic.

--

Impact:

Unknown. This is an indication of anomalous behaviour between networked assets.

--

Detailed Information:

This event is generated when the http_inspect preprocessor detects anomalous network traffic.

In particular, the preprocessor has detected a long client header in an HTTP request.

This event can be controlled using the ((http_inspect)) configuration options.

--

Affected Systems:

All networked systems.

--

Attack Scenarios:

--

Ease of Attack:

Simple.

Snorby Search

Snorby Advanced Search More Options

Match of the following rules:

☒	Choose a query term...	is	Enter search value	- +
☒		is	Enter search value	- +
☒		is	Enter search value	- +

- Source Address
- TCP Source Port
- UDP Source Port
- Destination Address
- TCP Destination Port
- UDP Destination Port
- Classification
- Signature
- Signature Name
- Classified By

Snorby 2.6.2 - <https://www.snorby.org> © 2016 Threat Stack, Inc - Created By: Dustin Willis Webber

Snorby Administration

Snorby
SPONSORED BY
threat stack
<https://threatstack.com>

Welcome Administrator | [Settings](#) | [Log out](#)

Dashboard | My Queue (0) | Events | Sensors | Search | **Administration**

General Settings

Company name

Company email (this email will be used as the report sender)

Signature lookup url (user \$\$sid\$\$ and \$\$gid\$\$ for the get request parameters)

☐ Enable snorby update notifications
(Notification reminder when a new Snorby build is release using <http://snorby.org/version>)

☐ Enable packet capture support
(Enable the Snorby Packet Capture Plugin)

☒ Daily reports
(Send a report summarizing the captured traffic daily.)

☒ Weekly reports
(Send a report summarizing the captured traffic weekly)

☒ Monthly reports
(Send a report summarizing the captured traffic monthly)

☒ Address lookups
(This option enables the analyst to perform basic queries on source addresses using external sources.)

☐ Enable global event notifications
(Show new event notifications globally. Event count since last check)

☐ Geoip
(Display GeoIP information on the events list)

☐ Prune database when event count is greater than
(Prune the database automatically when the event count exceeds your specified limit.)

General Settings

Classifications

Sensors

Lookup Sources

Asset Name Manager

Severities

Signatures

Users

Worker & Job Queue ctrl+3

Save Settings

Cancel

Snorby 2.6.2 - <https://www.snorby.org> © 2016 Threat Stack, Inc - Created By: Dustin Willis Webber

Listing Signatures

 Filter Signatures

Sev.	Signature Name	Event Count	
2	http_inspect LONG HEADER	100.00%	View
2	SERVER-IIS bdir.htr access	0.00%	View
3	ICMP test detected	0.00%	View
2	SERVER-WEBAPP carbo.dll access	0.00%	View
1	SERVER-OTHER Putty Server key exchange buffer overflow attempt	0.00%	View
2	SERVER-MAIL Novell NetMail APPEND command buffer overflow attempt	0.00%	View
1	BROWSER-PLUGINS CCRP FolderTreeView ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX function call access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ReserveGroup attempt	0.00%	View
1	SERVER-IIS cmd.exe access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ClientDBMiniAgentClose attempt	0.00%	View
1	SERVER-IIS cmd? access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor QSIGetQueuePath_Function_45 overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor ASRemotePFC overflow attempt	0.00%	View
2	SERVER-IIS codebrowser Exair access	0.00%	View
2	SERVER-IIS codebrowser SDK access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc2 ASDBLoginToComputer overflow attempt	0.00%	View
1	FILE-IMAGE Oracle Java Virtual Machine malformed GIF buffer overflow attempt	0.00%	View
1	BROWSER-FIREFOX Mozilla Firefox query interface suspicious function call access attempt	0.00%	View

1	SERVER-OTHER Peercast ORFET parameter overflow attempt	0.00%	View
1	BROWSER-FIREFOX Mozilla Firefox query interface suspicious function call access attempt	0.00%	View
1	FILE-IMAGE Oracle Java Virtual Machine malformed GIF buffer overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc2 ASDBLoginToComputer overflow attempt	0.00%	View
2	SERVER-IIS codebrowser SDK access	0.00%	View
2	SERVER-IIS codebrowser Exair access	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor ASRemotePFC overflow attempt	0.00%	View
1	NETBIOS DCERPC NCACN-IP-TCP brightstor QSIGetQueuePath_Function_45 overflow attempt	0.00%	View
1	SERVER-IIS cmd? access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ClientDBMiniAgentClose attempt	0.00%	View
1	SERVER-IIS cmd.exe access	0.00%	View
3	NETBIOS DCERPC NCACN-IP-TCP brightstor-arc ReserveGroup attempt	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX function call access	0.00%	View
1	BROWSER-PLUGINS Oracle ORADC ActiveX clsid access	0.00%	View
1	BROWSER-PLUGINS CCRP FolderTreeView ActiveX clsid access	0.00%	View
2	SERVER-MAIL Novell NetMail APPEND command buffer overflow attempt	0.00%	View
1	SERVER-OTHER Putty Server key exchange buffer overflow attempt	0.00%	View
2	SERVER-WEBAPP carbo.dll access	0.00%	View
3	ICMP test detected	0.00%	View
2	SERVER-IIS bdir.htr access	0.00%	View

[First](#)
[Previous](#)
[...](#)
[1131](#)
[1132](#)
[1133](#)
[1134](#)
[1135](#)
[1136](#)
[1137](#)
[1138](#)
[1139](#)

Detection Engine - Rules

Rule Header

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Alert tcp 1.1.1.1 any -> 2.2.2.2 any

Rule Options

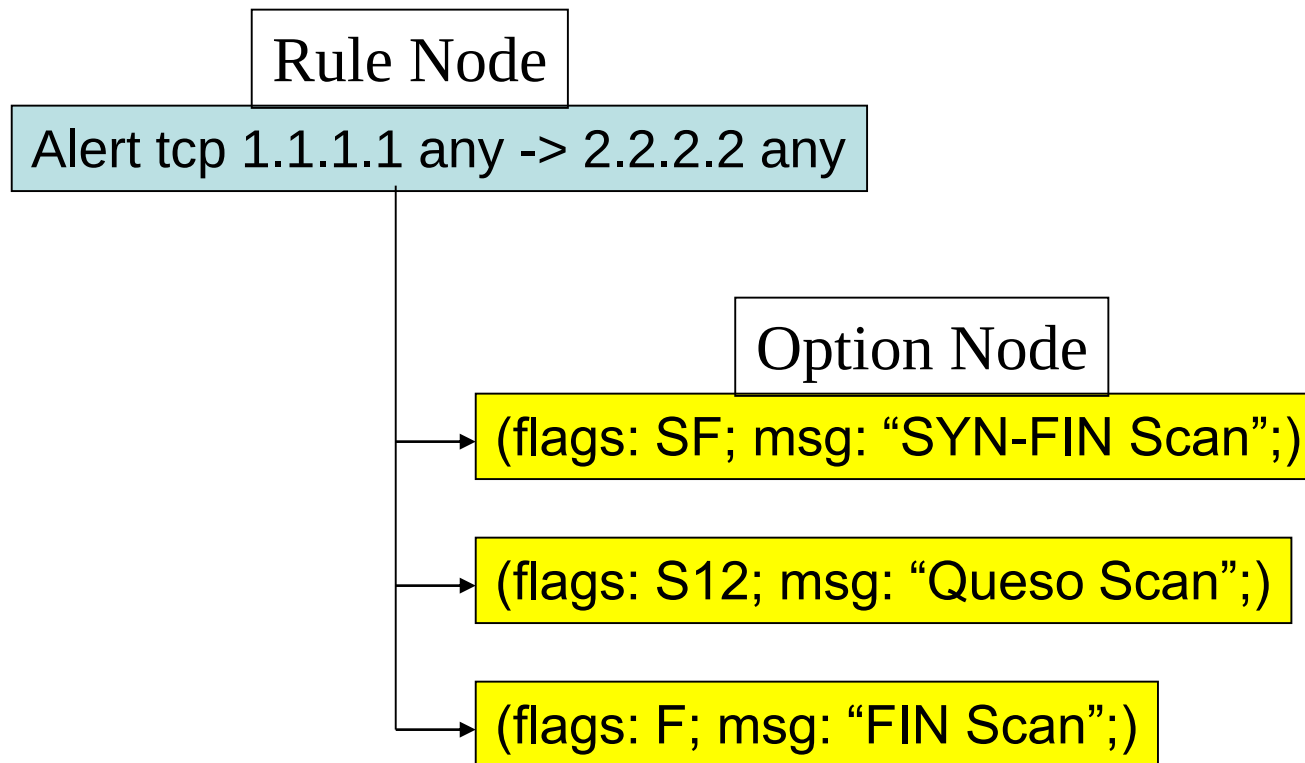
(flags: SF; msg: "SYN-FIN Scan";)

(flags: S12; msg: "Queso Scan";)

(flags: F; msg: "FIN Scan";)

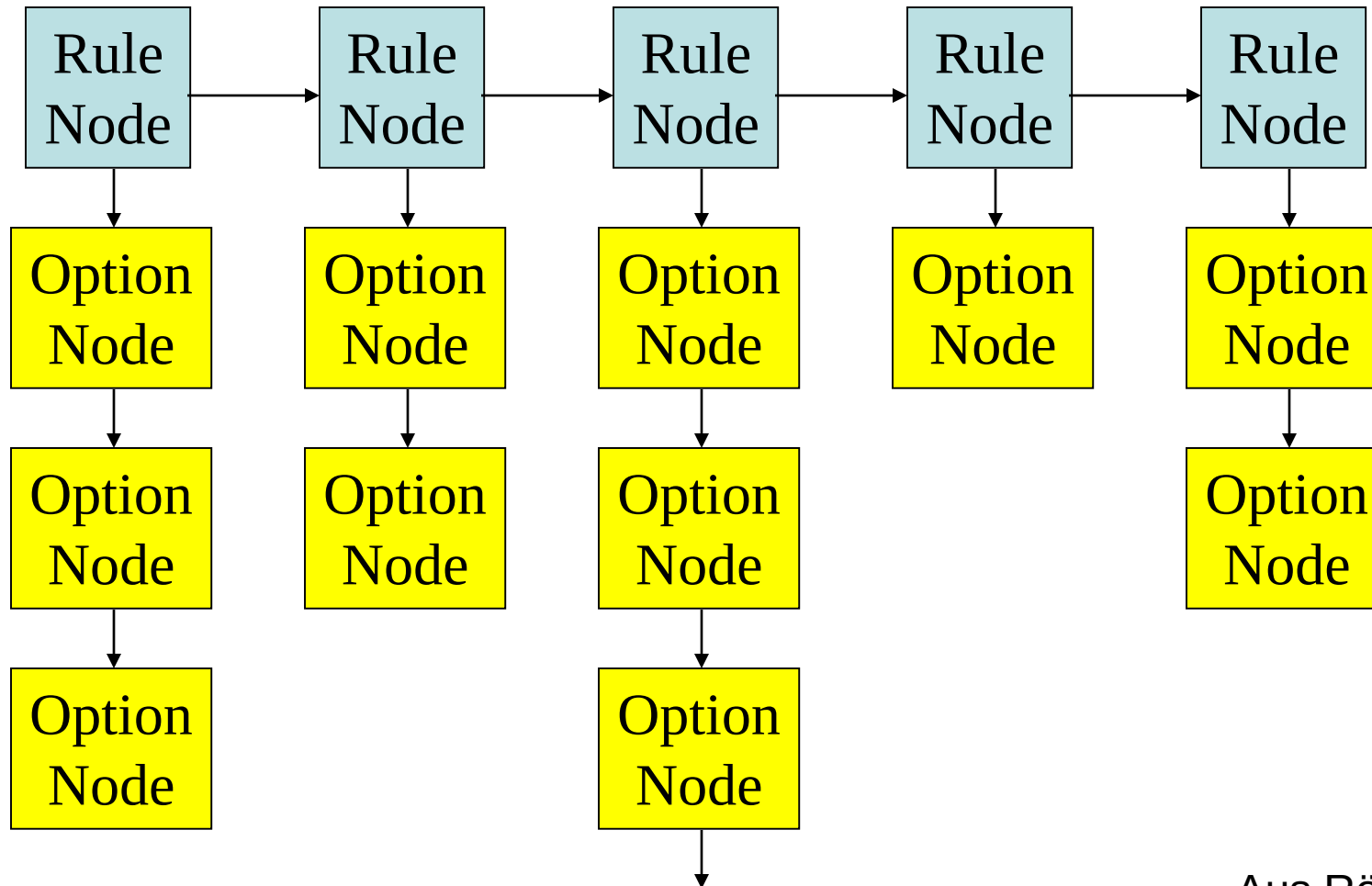
Aus Rösch 2008 Snort

Detection Engine – Interne Repräsentation



Aus Rösch 2008 Snort

Detection Engine - Gesamtsicht



Aus Rösch 2008 Snort

Heartbleed

- alert tcp \$HOME_NET [21 ,25 ,443 ,465 ,636 ,992 ,993 ,995 ,2484] -> \$EXTERNAL_NET any
(msg:' SERVER - OTHER OpenSSL TLSv1 .1 large
heartbeat response - possible ssl heartbleed attempt '
flow : to_client , established ;
content: '|18 03 02| ' ; depth :3; byte_test :2 > ,128,0,
relative ;
metadata : policy balanced - ips drop ,
policy security -ips drop , ruleset community , service
ssl;
reference : cve, 2014-0160; classtype : attempted - recon ;
sid :30517; rev :8;)

Directory Traversal Nginx

- alert tcp \ \$EXTERNAL_NET any -> \ \$HOME_NET \ \$HTTP_PORTS
(msg:' SERVER -WEBAPP nginx URI processing security
bypass attempt '
flow : to_server, established ;
content : '/' '../' ; depth :40; offset :5;
metadata : service http ;
reference : bugtraq ,63814;
reference :cve ,2013-4547;
reference :url , osvdb.org/show/osvdb/100015;
classtype : attempted - user ;
sid:33581; rev :1;)

DNS Cache Poisoning

- alert udp \ \$EXTERNAL_NET 53 -> \ \$HOME_NET any
(msg:' PROTOCOL -DNS large number of NXDOMAIN
replies - possible DNS cache poisoning';
flow : to_client ;
byte_test :1 ,& ,2 ,3; byte_test :1 ,& ,1 ,3; byte_test:1 ,&
,128 ,2;
detection_filter : track by_src , count 1000 , seconds 5;
metadata : service dns;
reference :cve ,2008-1447; reference :cve, 2009-0233;
reference :url , technet.microsoft.com/en-
us/security/bulletin/MS09-008;
reference :url , www.kb.cert.org/vuls/id/800113;
classtype :misc - attack ;
sid :13948; rev :11;)

Werkzeuge SNORT Referenzen

- KURUNDKAR, GD, NA NAIK und SD KHAMITKAR [2012]. „Network intrusion detection using Snort“. In: International Journal of Engineering Research and Applications 2.2, S. 1288–1296
- <https://www.snort.org/>
- M. Roesch. Snort: Lightweight intrusion detection for networks. In Proceedings of the 1999 USENIX LISA Systems Administration Conference, November 1999.
- <http://www.cisco.com/c/en/us/about/corporate-strategy-office/acquisitions/sourcefire.html>
- C. Kopetschny: Installation und Integration des Intrusion Detection Systems Snort, SARB DHBW Karlsruhe, 2016
- <https://www.heise.de/news/Snort-3-Mit-Multithreading-dem-Angreifer-auf-der-Spur-5032068.html>